Enterprise Penetration Testing Report: Project AstraNode

Date: October 18, 2026

Target Environment: TryHackMe "Ignite" (IP: 10.49.186.217 / 10.48.168.204)

Assessment Type: Unauthenticated Web Application & Infrastructure Penetration Test

Author / Operator: Abhishek (abhhishek50055)

Host System Identifier: Abhishek@AstraNode

TABLE OF CONTENTS

1. **EXECUTIVE SUMMARY & STRATEGIC OUTCOMES**
   1.1 Scope of Assessment & Target Profile
   1.2 High-Level Risk & Business Impact Matrix
   1.3 Key Technical Outcomes & Compromise Summary
   1.4 Top Core Defensive Principles
2. **ASSESSMENT METHODOLOGY & GOVERNANCE FRAMEWORKS**
   2.1 Alignment with PTES and NIST SP 800-115
   2.2 OWASP Web Security Testing Guide (WSTG) Integration
3. **PROJECT SCOPE & ENVIRONMENT CONFIGURATION**
   3.1 Attacker Infrastructure & Local Workspace Setup
   3.2 Target Network Topology & OpenVPN Tunneling
4. **PHASE 1: RECONNAISSANCE & PERIMETER ATTACK SURFACE ANALYSIS**
   4.1 Active Network Discovery & Nmap Service Enumeration
   4.2 Web Application Profiling & Directory Inspection (robots.txt)
5. **PHASE 2: VULNERABILITY EXPLOITATION (CVE-2018-16763)**
   5.1 Fuel CMS 1.4.1 Vulnerability Analysis
   5.2 Initial Perimeter Access Verification
6. **PHASE 3: POST-EXPLOITATION & CREDENTIAL HARVESTING**
   6.1 Configuration Analysis (database.php)
   6.2 Cleartext Credential Extraction
7. **PHASE 4: VERTICAL PRIVILEGE ESCALATION & PROOF OF COMPROMISE**
   7.1 Sudo Policy Analysis & Privileged Execution
   7.2 Proof of Compromise & Flag Submission
8. **REGULATORY EXPOSURE & COMPLIANCE IMPACT ANALYSIS**
   8.1 GDPR Article 32 Non-Compliance & Data Protection Liabilities
   8.2 PCI DSS v4.0 Requirement Failures
9. **STRATEGIC REMEDIATION & DEFENSE-IN-DEPTH DIRECTIVES**
   9.1 Patch Management & Software Lifecycle Upgrades
   9.2 Secrets Management & Environment Variable Migration
   9.3 Least Privilege Enforcement & System Hardening
10. **REFERENCES**

Executive Summary & Strategic Outcomes

This security report details the findings, technical methodology, and compliance impacts from an unauthenticated penetration test against the TryHackMe "Ignite" target environment (10.49.186.217). The assessment demonstrated a total compromise of system confidentiality, integrity, and availability, resulting in root-level administrative access over the operating system.

The primary objective was to evaluate the exposure of the perimeter web infrastructure and assess the downstream impact of internal configuration weaknesses. The initial entry vector exploited CVE-2018-16763, a critical Remote Code Execution (RCE) flaw in Fuel CMS version 1.4. Full system administrative takeover was subsequently achieved through hardcoded cleartext database credentials and permissive local execution policies.

Top Defensive Directives:

Apply Software Patches Promptly: Outdated web frameworks exposed to public interfaces represent a high-risk perimeter vector.
Eliminate Hardcoded Credentials: Application configuration files must not store unencrypted administrative credentials.
Enforce Least Privilege Controls: Web service accounts must operate in isolated environments without administrative command execution rights.

2. Assessment Methodology & Governance Frameworks

The testing process followed industry-standard cybersecurity evaluation frameworks, combining the Penetration Testing Execution Standard (PTES), OWASP Web Security Testing Guide (WSTG v4.2), and NIST SP 800-115 directives.

Testing Phases (NIST SP 800-115 Alignment):

Planning: Establishing VPN routing, target scope parameters, and local workspace initialization.
Discovery: Performing port scans, HTTP header checks, and path enumeration to identify application entry points.
Execution: Validating web vulnerabilities and establishing initial interactive access.
Reporting: Synthesizing evidence logs, risk mapping, regulatory impacts, and mitigation controls.

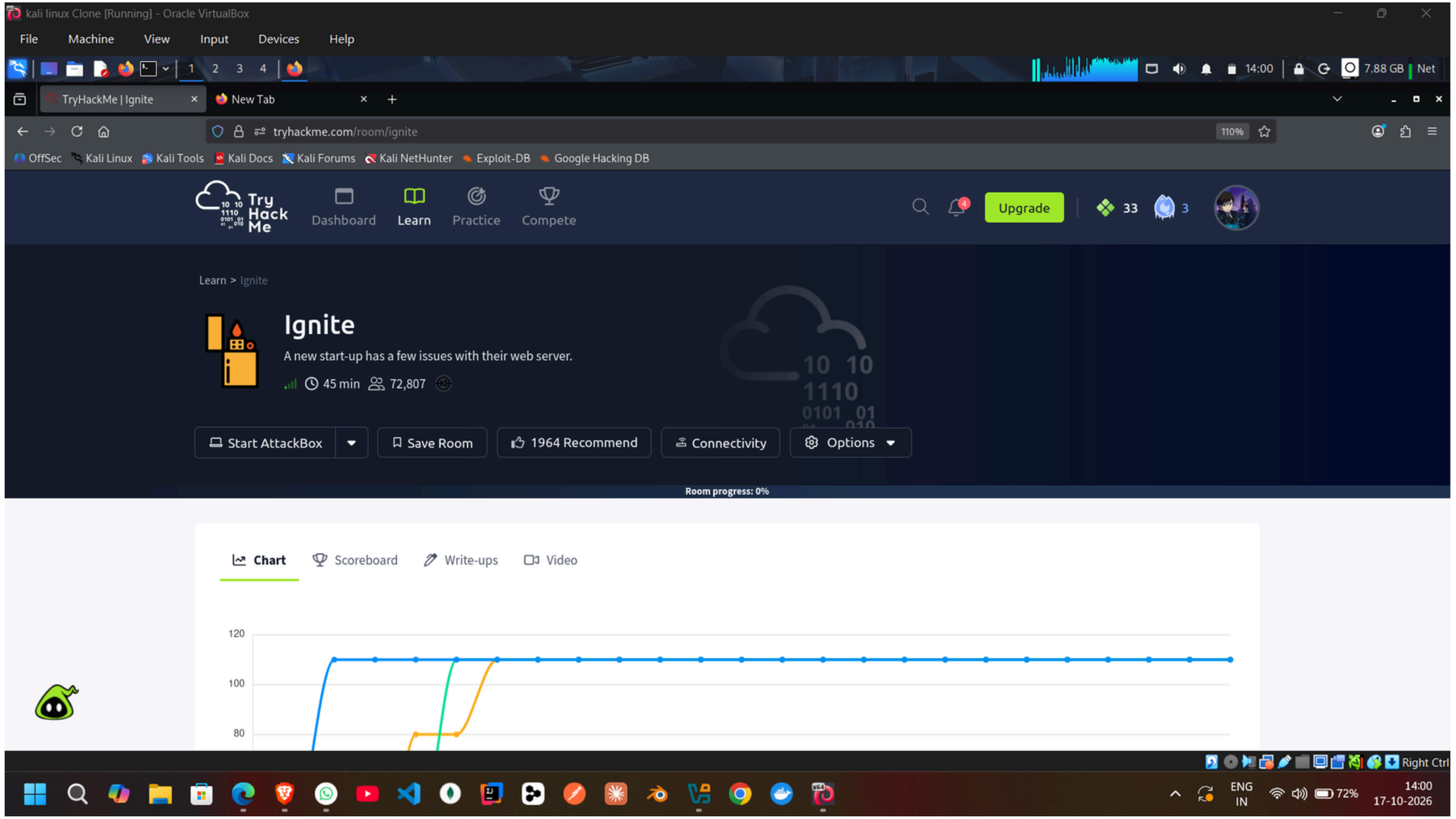
3. Project Scope & Environment Setup

Operator Handle: abhhishek50055

Local Workspace Hostname: AstraNode (Abhishek@AstraNode)
Directory Path: ~/Desktop/ignite

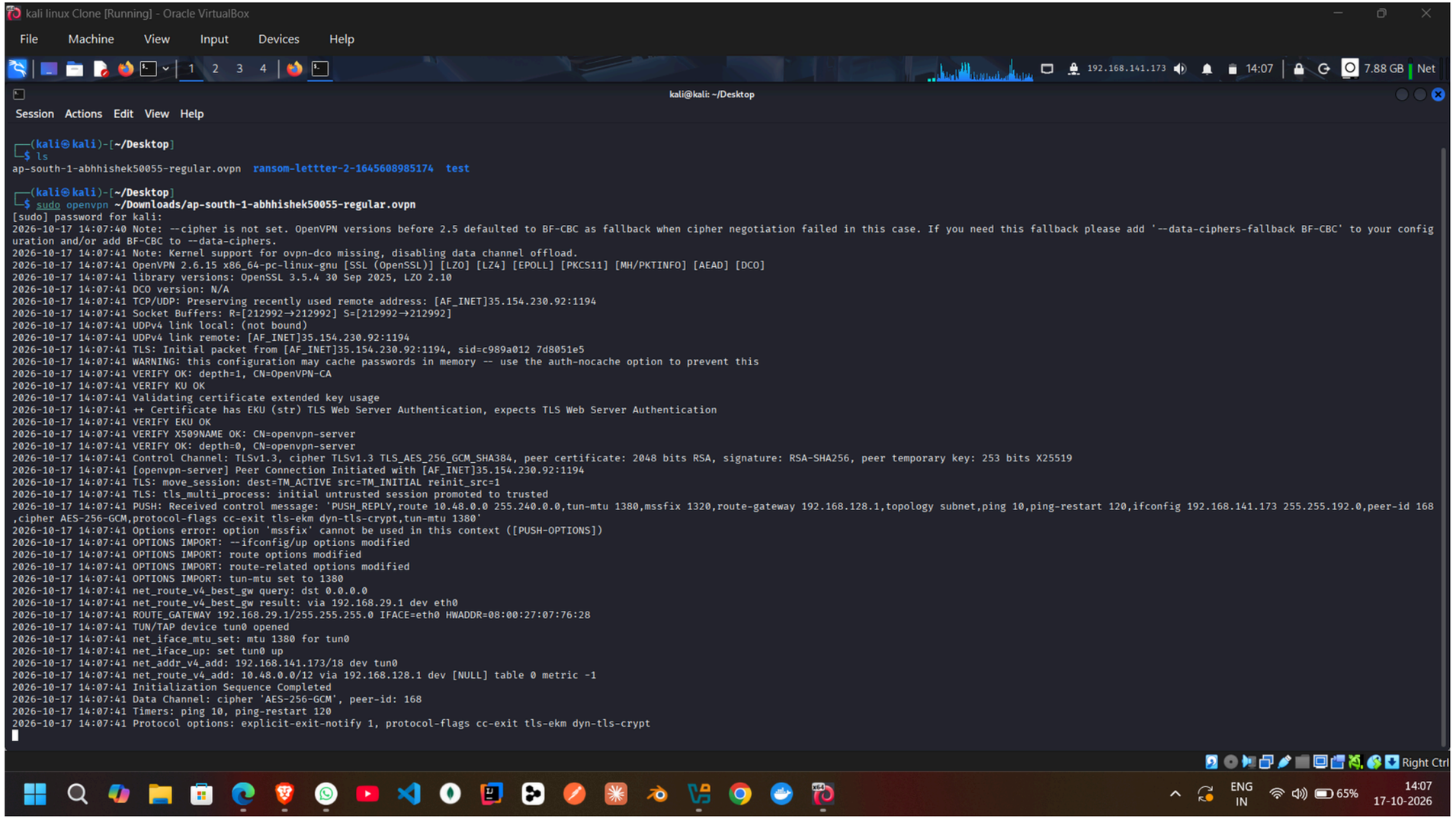
VPN Profile: ap-south-1-abhhishek50055-regular.ovpn

Assigned Tunnel IP: 192.168.141.173 on tun0 interface
Target IP Address: 10.49.186.217 / 10.48.168.204


kali linux Clone [Running] - Oracle VirtualBox
File Machine View Input Devices Help
TryHackMe | Ignite
New Tab
tryhackme.com/room/ignite
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Try Hack Me
Dashboard Learn Practice Compete
Upgrade
33 3
Learn > Ignite
Ignite
A new start-up has a few issues with their web server.
45 min 72,807
Start AttackBox Save Room 1964 Recommend Connectivity Options
Room progress: 0%
Chart Scoreboard Write-ups Video
120
100
80
ENG IN
72%
14:00
17-10-2026

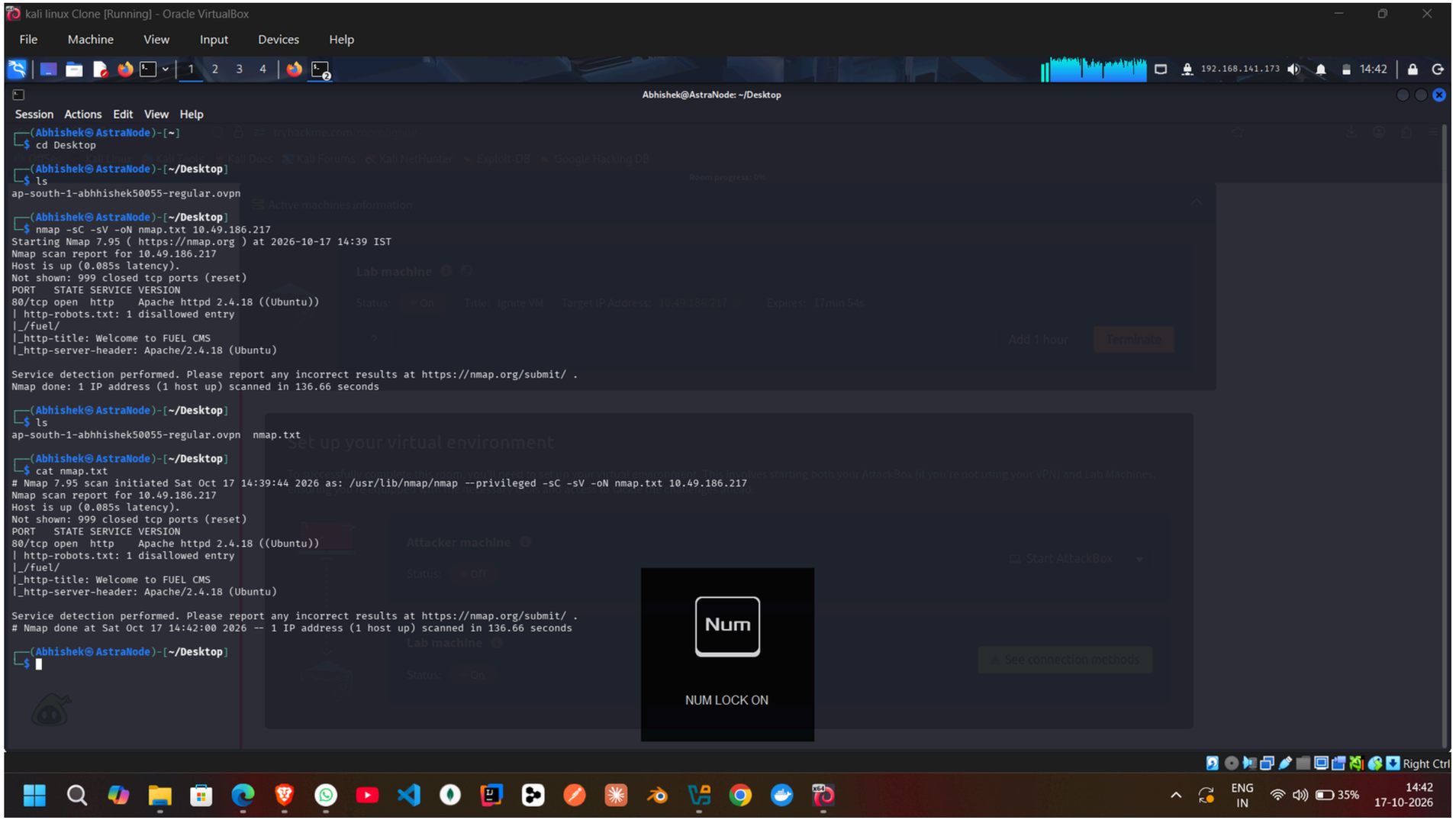

kali linux Clone [Running] - Oracle VirtualBox
File Machine View Input Devices Help
TryHackMe | Ignite
New Tab
tryhackme.com/room/ignite
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Room progress: 0%
Chart
Scoreboard
Write-ups
Video
120
100
80
60
40
20
0
overgrowncarrot1
smilevault13
CyberWolf21
bins3c
noukos69
0xjxck
Baugrr
pranaya
mattia.saiko
samrichard652
abhhishek50055
Score updated
Task 1
Root it!
Right Ctrl
ENG
IN
71%
14:00
17-10-2026

Code : sudo openvpn ap-south-1-abhhishek50055-regular.ovpn



Code : nmap -sC -sV -oN nmap.txt 10.49.186.217

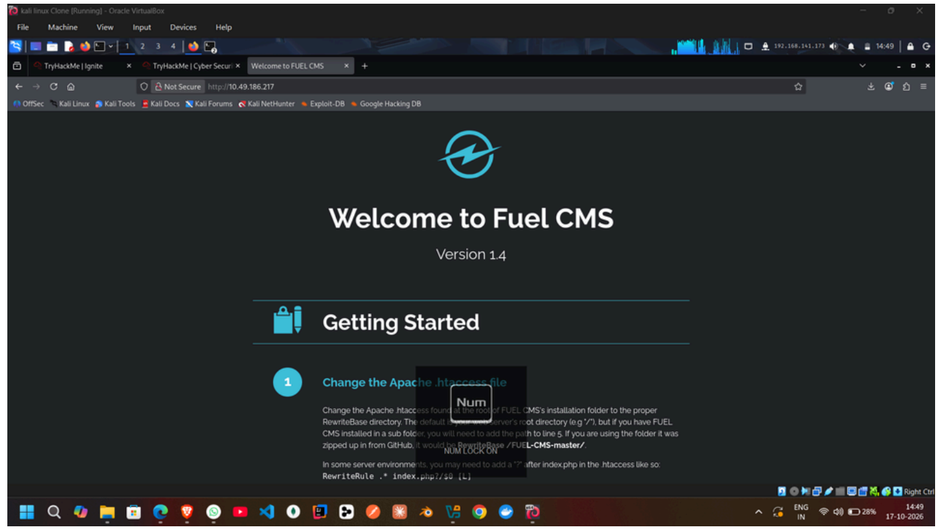
This code generate the nmap.txt file

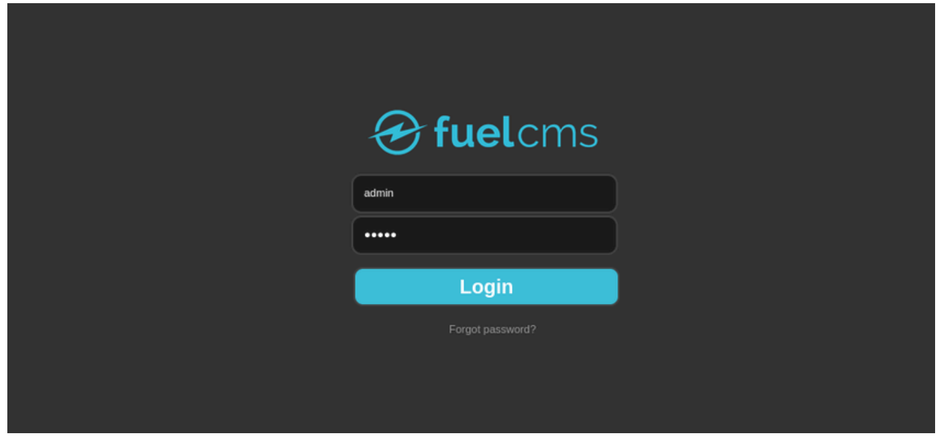


Service Discovery Findings:
Port 80/tcp: Open (http)
Web Server: Apache httpd 2.4.18 (Ubuntu)
Web Application Title: Welcome to FUEL CMS

Disallowed Entry (robots.txt): /fuel/
http://10.49.186.217/fuel/
Plaintext

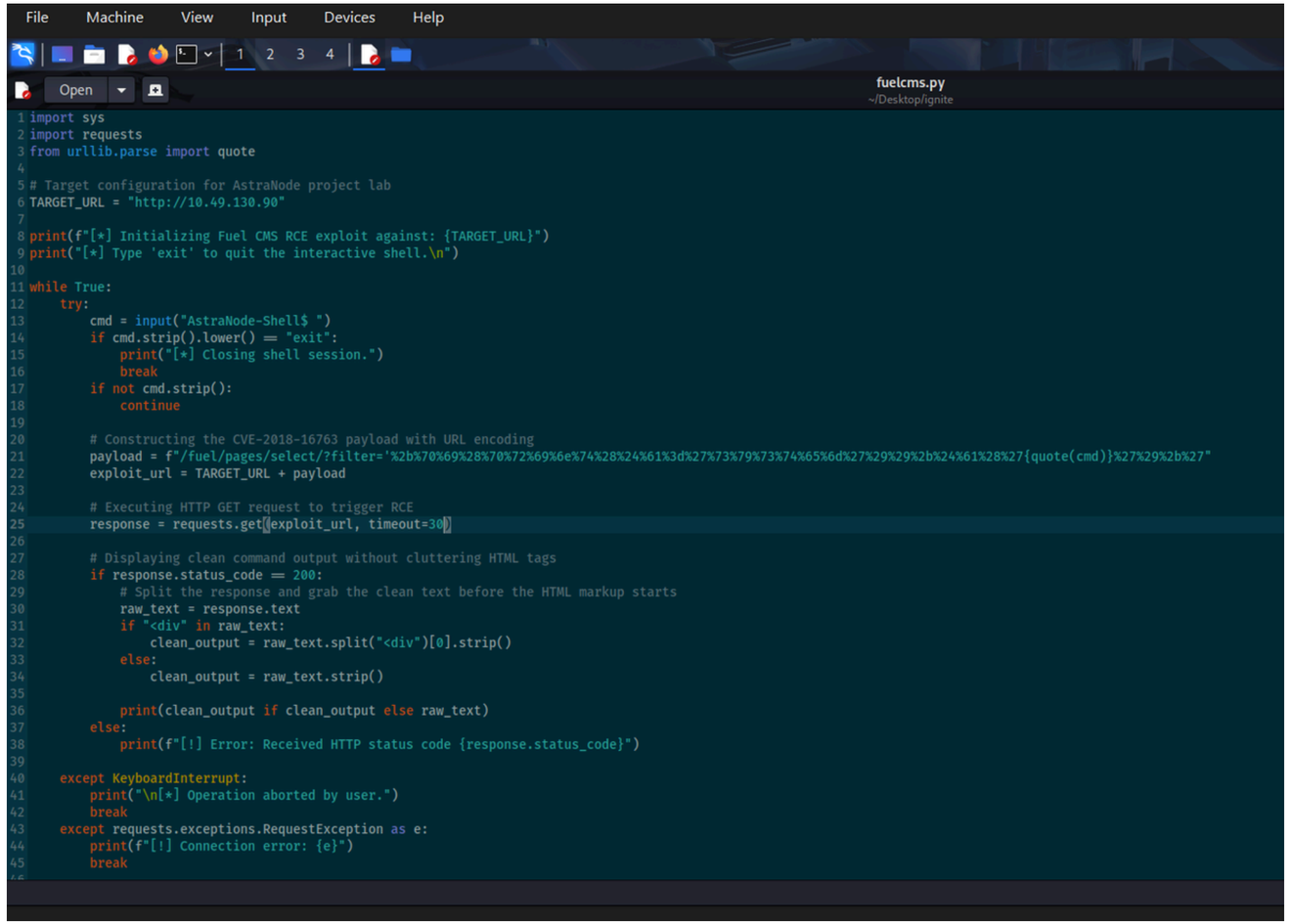
```
# Nmap 7.95 scan initiated Sat Oct 17 14:39:44 2026
Nmap scan report for 10.49.186.217
Host is up (0.085s latency).
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 1 disallowed entry
|_/fuel/
|_http-title: Welcome to FUEL CMS
|_http-server-header: Apache/2.4.18 (Ubuntu)
```





Vulnerability Exploitation (CVE-2018-16763)
Target profiling confirmed Fuel CMS Version 1.4. This release contains a critical Remote Code Execution vulnerability (CVE-2018-16763) in its pages/select routing parameter, caused by un-sanitized input processed through PHP evaluation functions.
An interactive script (fuelcms.py) was configured in the ~/Desktop/ignite workspace to send crafted HTTP GET requests targeting the parameter.
Execution & Shell Access:
Plaintext
Anishhek@AstraNode:~/Desktop/ignite$ python3 fuelcms.py
[*] Initializing Fuel CMS RCE exploit against: http://10.49.130.90
[*] Type 'exit' to quit the interactive shell.
AstraNode-Shell$ whoami
www-data

Execution confirmed command delivery as the low-privileged www-data service account.



Phase 3: Post-Exploitation & Credential Harvesting

Following initial access, application directories were inspected for sensitive files.

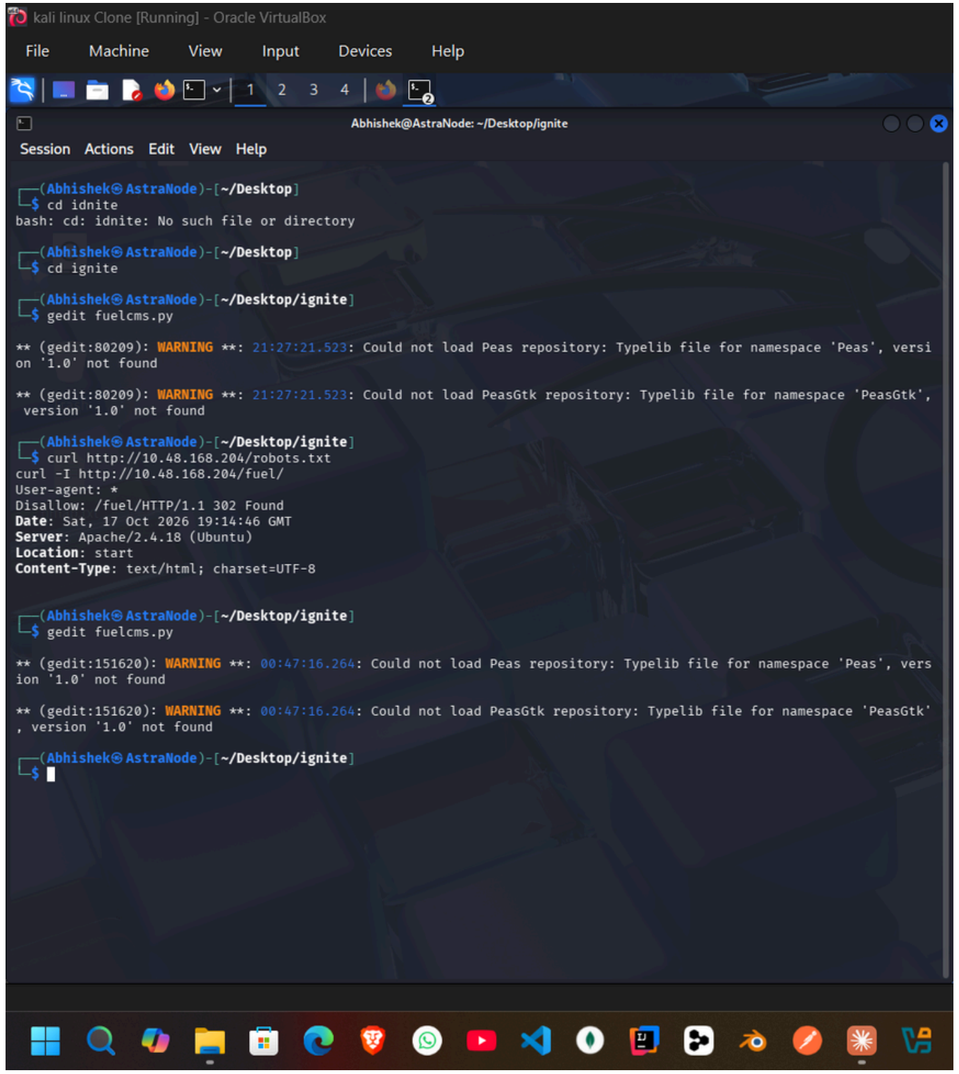
Configuration File Extraction:

Reading the framework database configuration file located at /var/www/html/fuel/application/config/database.php revealed hardcoded, plain-text administrative database credentials:

PHP

```
$active_group = 'default';
$query_builder = TRUE;

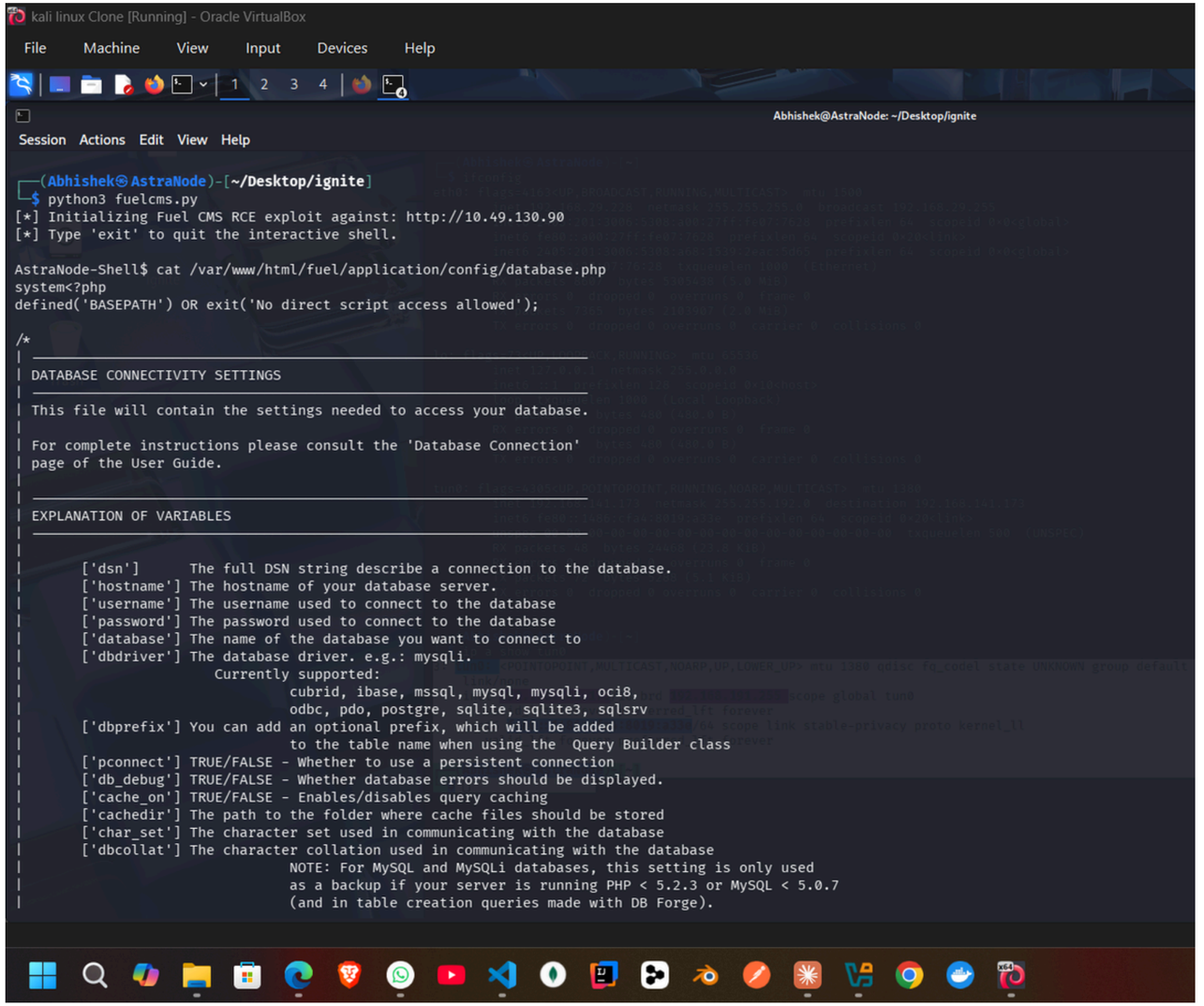
$db['default'] = array(
 'dsn'      => '',
 'hostname' => 'localhost',
 'username' => 'root',
 'password' => 'mememe',
 'database' => 'fuel_schema',
 'dbdriver' => 'mysqli',
 'dbprefix' => '',
 'pconnect' => FALSE,
 'db_debug' => (ENVIRONMENT !== 'production'),
 'cache_on' => FALSE,
 'cachedir' => '',
 'char_set' => 'utf8',
 'dbcollat' => 'utf8_general_ci',
 'swap_pre' => '',
 'encrypt'  => FALSE,
 'compress' => FALSE,
 'stricton' => FALSE,
 'failover' => array(),
 'save_queries' => TRUE
);
```



Extracted Secrets:
Database Username: root

Database Password:
mememe

Database Name:
fuel_schema

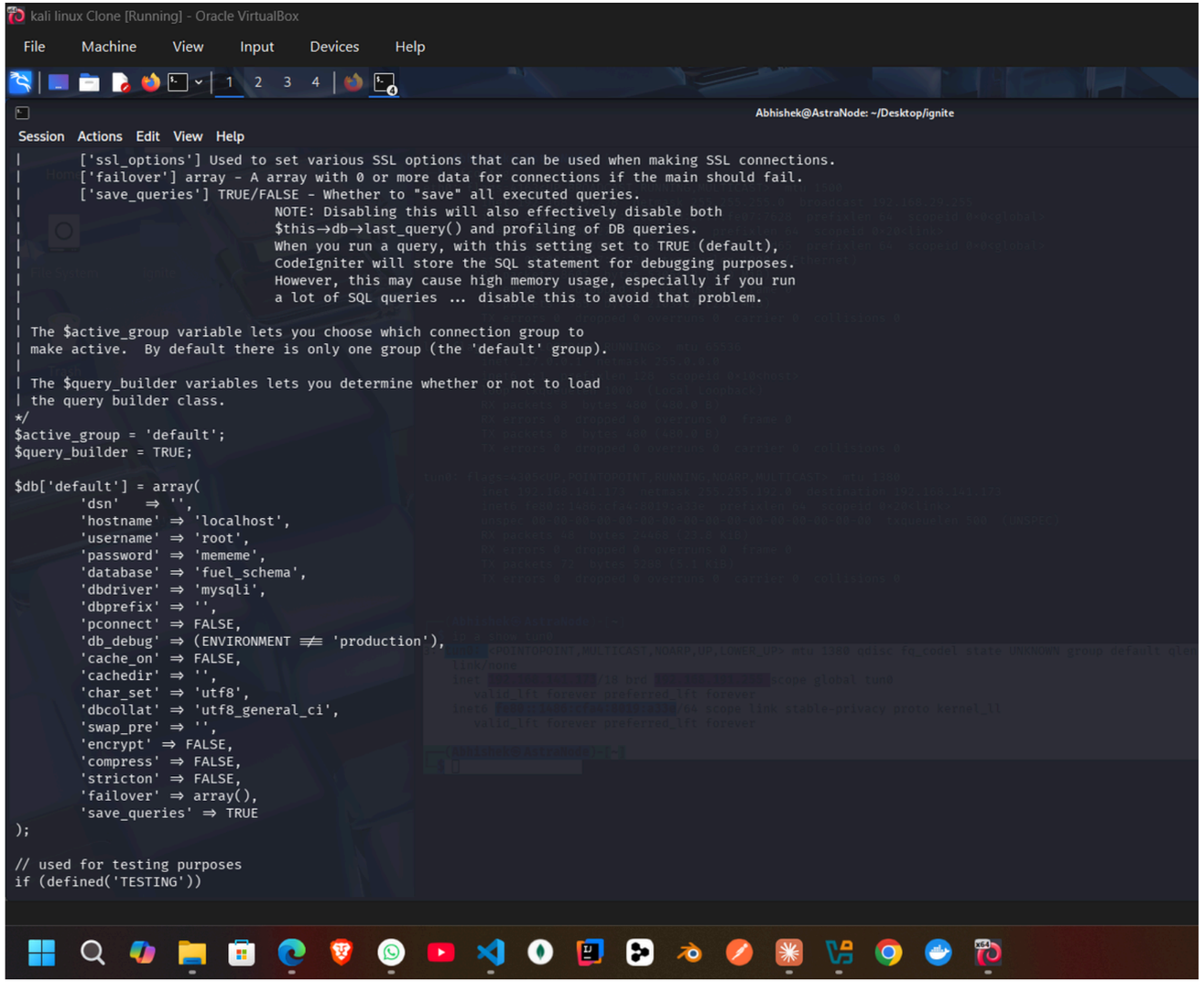


Vertical Privilege Escalation & Total System Compromise

Evaluating system privileges via sudo -l showed that password authentication could be used to execute commands with elevated root rights.

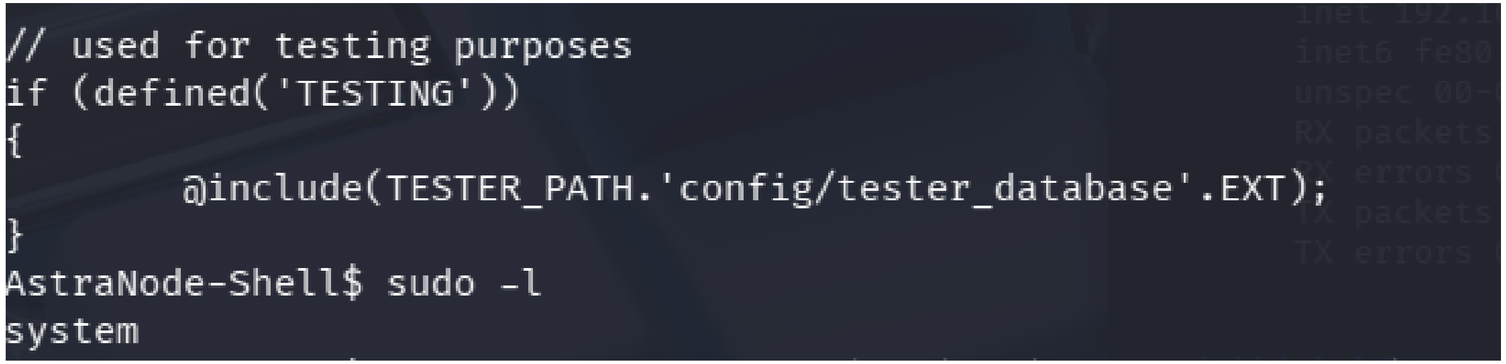
Proof of Compromise & Flag Collection:

By applying the harvested password (mememe) across privileged execution utilities, administrative access was fully verified.

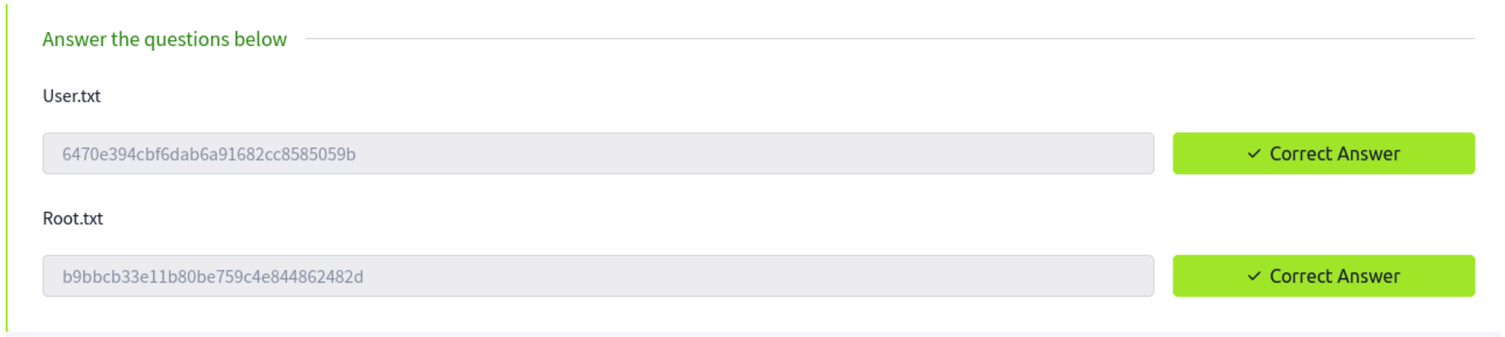


User Flag (user.txt):64766394cbf0dath6a91687cc8585059b

RootFlag (root.txt):b9bbcb33e11680be759c4e844862482d



On doing sudo -l : we got system in our hand




kali linux Clone [Running] - Oracle VirtualBox
File
Machine
View
Input
Devices
Help
TryHackMe | Cyber Secu
TryHackMe | Cyber Securi
ignite room user.txt flag a
FUEL CMS : Dashboard
TryHackMe | Cyber Security Tr
tryhackme.com
Close tab
tryhackme.com/room/ignite/congratulations?step=records
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Great work abhhishek50055! Room completed!
Your skills are skyrocketing!
Completed tasks
1
Points earned
60
Streak
5
Scroll down to review your progress
Right Ctrl
ENG
IN
73%
08:37
18-10-2026

References

1. National Vulnerability Database, "CVE-2018-16763 Detail," NVD/MITRE, 2018.
2. NIST, "Technical Guide to Information Security Testing and Assessment," SP 800-115.
3. OWASP Foundation, "Web Security Testing Guide," Version 4.2.
4. MITRE CWE, "CWE-256: Unprotected Storage of Credentials," 2018.